

GuardFrame 專題發表講稿 (初次預演版)

目標聽眾：非技術背景 (如各公司 HR)。全程避免技術名詞，用生活化比喻取代。

抓時間：全文約 6-8 分鐘朗讀速度，可依現場情況刪減「補充說明」段落。

一、開場：先讓聽眾感受到「這是真的會發生的事」(約 1.5 分鐘)

大家好，我們這組要解決的問題是：**現在用手機開銀行帳戶，你以為在鏡頭前眨眼、轉頭、就能證明「這是我本人」——但這個防線正在被攻破。**

先問大家一個問題：如果我拿到你的身分證照片 (不管是買來的、偷來的，還是社交工程騙來的)，然後我自己坐在鏡頭前，用一套換臉軟體，把我的臉即時換成你的臉——這時候系統要求我眨眼、轉頭、對著鏡頭笑一下，我全部都做得到。因為**動作是我真人做的，只有臉被換掉而已。**

這不是想像中的威脅，是已經發生的事。今年 (2026) 4 月，就有攻擊者用這招，透過荷蘭一家銀行的手機開戶流程，一次開出 **46 個詐欺帳戶**。而且產業數據顯示這類攻擊正在爆炸性成長：換臉攻擊已經佔所有 AI 詐欺攻擊的四成以上，兩年前這個比例還不到一成。

這對銀行意味著什麼？

- 帳戶被冒用去洗錢、詐欺，銀行要負法遵責任
- 每一筆都要人工複核的話，數位開戶「快速、免臨櫃」的優勢就沒了
- 一旦被媒體報導「XX銀行帳戶遭冒名開戶」，信任度直接受傷

現有的防偽系統為什麼擋不住？

因為市面上的方案主要是看「這張臉看起來像不像是合成的」——用 AI 判斷畫面本身。但問題是，換臉技術每一代都在進步，光看畫面判斷的準確率會隨著攻擊技術變強而持續下降，而且銀行也很難自己驗證這個「AI 判斷」到底準不準。

所以我們的核心想法是：**不能只看「臉看起來像不像真的」，要去找那些換臉軟體「做不到」或「很難模仿」的線索。**

二、我們做了什麼：一個比喻先建立整體印象 (約 1 分鐘)

我們把這個系統想成銀行開戶流程裡的**第二道海關安檢**——第一道是身分證件辨識 (人跟證件上的人是不是同一個)，我們做的是第二道：**確認鏡頭前的這個人，沒有被任何軟體動過手腳。**

而且我們不是只用一種方法檢查，是同時用**四種完全不同角度**的檢查方式，同時進行、互相佐證。就像機場安檢不會只靠一台X光機，還會有金屬探測、證件比對、人工目視——**任何一種方法都可能被騙過，但四種同時騙過去，難度完全不同等級。**

三、走一次使用者流程 (配合實機/畫面展示，約 1 分鐘)

(這段搭配 Demo 畫面講解)

使用者的體驗其實很單純，跟一般數位開戶沒有兩樣：

1. 填基本資料、輸入簡訊驗證碼
2. 上傳身分證照片
3. 對著鏡頭做幾個簡單動作——眨眼、轉頭這類的
4. 幾秒鐘後，系統就給出結果

使用者完全感覺不到背後在做什麼，但這短短 23 秒的錄影，我們同時在跑四層完全不同的分析。這也是我們一開始設計時很堅持的一點：**防禦要加強，但不能讓使用者多做任何額外的事、多等待更久。**

四、四道防線，逐一用比喻講清楚（重頭戲，約 2.5 分鐘）

這邊建議每個 Track 都用「這個技術想抓的是什麼漏洞」+「生活化比喻」的方式講，不要提技術名詞（rPPG、光譜、AUC 這些字完全不要出現在口語講稿裡）。

第一道：合成偵測 —— 「照妖鏡」

最直覺的一道：直接看畫面本身有沒有 AI 生成留下的痕跡。這是市面上大家都有的基本功，我們把它當作**第一層粗篩**，但正如剛剛說的，這道防線會隨換臉技術進步而變弱，所以它只是四道防線裡的其中一道，不是全部。

第二道：生理訊號偵測 —— 「量心跳」

這個是我們覺得最巧妙的一道。**真人的臉上，血液流動會讓皮膚顏色出現極細微、肉眼看不到的週期性變化**——這其實就是心跳的訊號。我們的鏡頭能從影片裡把這個訊號抓出來，算出心跳。

關鍵在於：換臉軟體只是把「臉的長相」貼上去，它沒辦法無中生有一個跟真實血流同步的心跳訊號。如果鏡頭前這張臉是被置換過的，這個「心跳訊號」要嘛量不到、要嘛雜亂沒有規律。這就是一個換臉軟體很難偽造的線索。

第三道：光線反應測試 —— 「打光測謊」

我們會讓螢幕短暫閃過幾種不同顏色的光，然後看**臉上的反光跟明暗變化，是不是符合真實世界的物理反應**——光線應該有自然的延遲、自然的明暗曲線。

如果對方是拿著螢幕在翻拍照片、或是用軟體去偽造畫面，這個光線反應會跟「真實一張立體臉在真實環境中」的反應對不起來。這是**物理世界騙不了的線索**。

第四道：遮擋一致性測試 —— 「破綻最容易露出來的一關」（我們的核心防線）

我們會請使用者用手在臉前面揮一下，短暫遮住部分臉部。**這個動作對真人來說毫無難度，但對即時換臉軟體來說，是最容易出破綻的時刻**——因為軟體要即時處理「手從遮住到移開」這個過程中，臉部合成的穩定度很容易在這幾格畫面裡露餡：可能有輪廓抖動、身分特徵瞬間不一致的情況。

這是我們特別強化的一道防線，因為它專門針對「即時操作型」的換臉攻擊設計，而不是針對照片或預錄影片。

五、四道防線之後，怎麼下結論？（約 1 分鐘）

四道防線各自算出一個分數，我們把它們**加權整合成一個總風險分數**，然後分成三種結果，這裡可以用紅黃綠燈的比喻：

- **綠燈（低風險）**：直接通過，使用者馬上可以完成開戶，體驗跟平常一樣快
- **黃燈（中風險）**：不會直接放行也不會直接拒絕，而是送進**銀行風控人員的後台**，人工看一次完整的證據（包含我們四道防線各自的判斷依據），由人來做最後決定
- **紅燈（高風險）**：直接擋下，不放行

這個設計的重點是：把人力資源集中在真正有疑慮的案件上，而不是每一筆都要人工看、或是完全不看直接放行冒風險。而且每一筆驗證的完整判斷依據都會留存下來，這對銀行來說很重要——監管機關要求銀行對開戶流程要能事後稽核、講得出「這個帳戶當初是怎麼通過的」。

六、先發防守：「為什麼不乾脆用一個很強的 AI 模型判斷就好？」（約 1 分鐘）

這段的目的：讓評審知道我們**討論過這條路、有能力做這條路，但主動選擇不走**，不是做不到。放在這裡（四道防線講完之後、總結之前）是因為此時評審心裡最容易浮現這個疑問，直接接住最有說服力。

到這邊大家可能會想：現在的多模態 AI 模型已經這麼強了，為什麼不乾脆丟一段影片給一個強大的模型，直接問它「這是真人還是換臉」，一個模型就搞定，何必拆成四層這麼麻煩？

老實說，我們知道**如果有一台夠強的地端大模型，理論上單靠它就能做到這件事**。但我們評估後，還是選擇拆成四個輕量的小模組，主要考量是**現實中的裝置條件**，而不是規則或誰厲害誰不厲害的問題：

最主要的原因：不是每個使用者的裝置都跑得動一個強大的模型。開戶的人可能用的是好幾年前的舊筆電、普通的家用網路，不會人人都有高規格的硬體。一個夠強、能即時理解整段影片的大模型，需要不小的運算資源；如果驗證體驗會因為使用者裝置不夠力而變慢、甚至跑不動，這在實際商轉上是不可行的。**我們拆成四個各自很輕量的小模組，是為了讓驗證能在一般使用者的日常裝置上就順利即時完成，不要求使用者有特別好的設備**。

另外還有兩個附帶的考量：一是使用者的即時人臉影片屬於敏感的生物特徵資料，模組化的設計讓資料處理的每一步都更單純、更容易控管；二是每個小模組各自輸出的是可以量化的中間結果（例如有沒有偵測到心跳訊號、光線反應的相關程度），這讓我們自己在開發跟驗證系統效果的時候，比較容易知道「是哪一部分在起作用」，方便持續調整優化。

這裡要特別說明一下：**我們並不清楚各家銀行內部實際採用的是什麼系統、用什麼規格的設備**，這不是我們能評論或假設的範圍。我們想強調的單純是：在「不確定使用者裝置條件」這個前提下，拆成小模組是比較穩妥、比較容易落地的工程選擇，這是根據現實限制做的取舍，不是說我們找到了什麼銀行系統做不到的事。

七、收尾：一句話總結（約 30 秒）

「眨眼、轉頭這類動作指令，換臉軟體本來就模仿得來，因為驅動畫面的是真人本人。我們想補上的，是那些換臉軟體很難同時模仿的線索——心跳訊號、光線的物理反應、遮擋瞬間的身分穩定度。這套系統不是要挑戰誰的防線，而是希望在整個數位開戶的驗證環節裡，多補上一層本來就容易被忽略的防禦角度。」

補充：如果 HR 聽眾提問，可能會問的問題與簡答

- **Q：這個跟一般的「活體偵測」(liveness) 有什麼不一樣？**

A：傳統活體偵測是為了排除「不是真人」的攻擊，例如拿照片、拿影片來騙鏡頭。但我們要防的是「本人真的在鏡頭前」但臉被即時置換的狀況，這種情況傳統活體偵測會誤判成通過。

- **Q：如果換臉技術也能模仿心跳訊號怎麼辦？**

A：這也是為什麼我們同時用四種方法而不是只靠一種——要讓攻擊者同時騙過心跳訊號、光線物理反應、還有遮擋瞬間的身分穩定度，難度是等級上的差異，不是單一漏洞。

- **Q：每個 Track 的判斷標準是什麼？**

A (口語總說)：四道防線各自看完全不同的線索，判斷方式都是「看這個訊號符不符合真人在真實物理世界裡該有的樣子」。

- — **Track 1 (合成偵測)**：抽樣10張臉部影像，丟進一個凍結的視覺基礎模型抽特徵，再用訓練過的分類器算出「這張臉是合成的機率」(0~1分，內部判斷門檻約0.5)，同時輸出貢獻度最高的三項判斷依據。**能力邊界**：只能看畫面內容本身有沒有生成痕跡，如果攻擊者是直接注入一段預錄的真實影片 (不是即時換臉)，Track1判斷不出來，這種情況要靠對照組動作題跟Track3的光線反應來抓，這是架構設計上的預期分工，不是Track1的缺陷。
- — **Track 2 (心跳訊號)**：從額頭、左右臉頰三個區域抓皮膚顏色的微小週期變化，濾波後用FFT算出心跳頻率。三個條件都要過：①主頻要落在生理合理範圍、②訊噪比要達標 (≥ 3.0 dB，訊號夠乾淨不是雜訊)、③三個區域算出來的心率彼此差異要小於5 bpm (代表這是全臉一致的真實生理訊號)。
- — **Track 3 (光線反應)**：螢幕依序閃過5段不同顏色 (每段0.4~0.6秒)，看臉部亮度變化跟螢幕光序列對不對得起來。三個條件：①亮度序列跟光源序列的相關係數要達標、②反應延遲要合理 (數十毫秒等級，太慢代表可能是螢幕重新拍攝或後製疊加)、③臉部不同區域 (額頭/鼻梁/臉頰) 的反光強弱要符合立體臉部的幾何反射模式，不是一整片平面式的反光。
- — **Track 4 (遮擋一致性，核心防線)**：請使用者揮手遮臉，追蹤每次「手進入→離開」的完整循環，對每個影格算身分特徵，看相鄰影格的身分相似度有沒有掉下來。三個條件：①至少偵測到2次完整揮手循環、②遮擋前後的身分特徵相似度要維持穩定，不能出現大幅度突降、③手跟臉重疊區域的顏色紋理要符合「手蓋在臉前面」該有的遮擋層次關係，不能有臉部紋理從手的縫隙透出來 (透出來通常代表換臉合成沒跟手做好深度遮擋處理)。
- — **融合階段**：四層 (加上動作對照組共五層) 各自算出風險分數，依預設權重加權合成0~100分的總風險分數，再依分數區間分成通過 / 人工複核 / 拒絕三段。

A (如果被迫問到具體數字)：可以誠實補充，這些門檻數字是團隊依實測資料反覆校準調整過的，設定檔裡的數字才是目前實際運作採用的版本，跟早期規格文件寫的初版數字可能有落差，這是正常的校準過程，不是文件寫錯或臨時想不起來。

- **Q：權重是怎麼決定的？**

A：目前是依各層防禦的重要性給預設權重，遮擋一致性 (Track 4) 因為是針對即時換臉攻擊特別設計的核心防線，權重相對較高，實際比例會在校準階段用測試資料進一步調整，不是隨意設定的數字。

- **Q：誤判怎麼辦 (正常用戶被擋)？**

A：這就是三段式分流存在的原因，中間地帶不會直接拒絕，會進人工複核，由人做最後判斷，不會單靠系統一次判死刑。